

Resumo de Estudo — Segurança em Redes de Comunicações

Preparação para o exame teórico · Baseado nos exames de 2023–2026 e nos slides da cadeira

1. Em que matéria te deves focar (análise dos exames)

Todos os exames (2023–2026) seguem a mesma estrutura: é dada uma rede empresarial em anexo (edifícios com VLANs, DMZ, datacenters, firewalls, routers com OSPF) e pedem-se 4–5 grupos de questões. A comparação entre exames mostra um **núcleo estável** que aparece sempre, e tópicos que caíram em desuso. Dando mais peso aos exames mais recentes (2025 e sobretudo 12/junho/2026), a prioridade é:

Prioridade	Tema	Peso típico	Aparece em
★★★★★	Zonas de rede + regras de firewall (controlo de fluxos)	5–6,5 val.	TODOS os exames
★★★★★	SIEM: fontes de dados, coleta e regras de alerta	5–7,5 val.	TODOS os exames
★★★★■	Proteção contra DDoS (arquitetura multi-nível) e IP spoofing	2–5 val.	TODOS os exames
★★★★■	Ligações seguras: IPsec, OpenVPN, DMVPN, PKI/CA/certificados	3–5,5 val.	TODOS os exames
★★★██	Segmentação L2/L3: VLANs, trunks, inter-VLAN routing	4 val. em 2026!	2026 (Q1) + contexto de todos
★★███	IDS/IPS/NDR: pontos de captura de tráfego (tap, mirror, ERSPAN, suplote)	—	Suporte às questões DDoS/SIEM
★███	Fases de um ataque (recon., infiltração, exfiltração)	2–3 val.	2023–2024; desapareceu em 2025/26
★███	Access Control (802.1X, RADIUS, EAP, WiFi/WPA)	—	Nunca perguntado diretamente

Sobre o Corporate_Network_Topics.pdf: tens razão em parte — a maioria (design hierárquico, OSPF em detalhe, EIGRP, IS-IS, redistribuição) é fundamento de redes e nunca é perguntada diretamente. **MAS** a secção de VLANs/segmentação (slides 21–29) tornou-se diretamente examinável: a questão 1 do exame de 2026 (4 valores) pergunta porque é que uma única VLAN por edifício facilita a propagação de ameaças e pede alterações L2/L3. Além disso, perceber o anexo do exame (trunks, OSPF, rotas por omissão) exige as noções básicas desse PDF. Estuda só essas partes.

Tendências importantes de 2023 → 2026

- As «**fases de um ataque**» (Q1 de 2023/2024) desapareceram; em 2025/2026 a Q1 passou a ser sobre **arquitetura** (DDoS/IP spoofing em 2025; segmentação VLAN em 2026).
- O exame de 2026 introduziu **IPsec com autenticação por certificados de uma CA local** (pedido/validação/download por HTTP/80) — junta VPN + PKI + regras de firewall na mesma questão. Já tinha aparecido em 2025 (Q3c).
- No SIEM, os cenários repetem-se com variações: DDoS, exfiltração lenta (via DNS ou via HTTPS/serviço autorizado), C&C; de botnet, propagação lateral de worms, testes de vulnerabilidade/brute force.
- As regras de firewall pedem sempre: **zonas envolvidas + firewall onde a regra é aplicada + sentido + IP/portas origem e destino + ação**. Treina com os serviços dos enunciados (backup, OpenVPN, IPsec, HTTPS).

2. Controlo de fluxos: zonas e regras de firewall ★★★★★

2.1 Conceitos-chave

- **Micro-segmentação / Zero Trust:** dividir a rede em zonas pequenas com políticas próprias; o tráfego entre zonas passa sempre por um ponto de controlo (firewall). Nada é confiável por omissão.
- **Zonas típicas a definir no exame:** Exterior/Internet, DMZ (serviços públicos), Datacenters internos (um por datacenter, ou sub-zonas por serviço), zonas de utilizadores (por VLAN/edifício), zona de gestão, e zonas virtuais para redes VPN (ex.: 192.168.10.0/24 dos utilizadores remotos).
- **Firewalls stateful vs. stateless:** stateful acompanha o estado das ligações (permite responder sem regra de retorno explícita, mas consome memória → vulnerável a SYN floods); stateless filtra pacote a pacote (rápida, ideal para a primeira linha de defesa anti-DDoS).
- **Firewalls addressed vs. stealth:** com endereço IP nas interfaces (routing) vs. transparentes/bridge sem IP.
- **Instâncias virtuais** de firewall: uma firewall física pode ter instâncias isoladas para zonas diferentes.

2.2 Como escrever regras no exame (receita)

Para cada requisito do enunciado: (1) identifica origem e destino e as **zonas** a que pertencem; (2) identifica **todas as firewalls no caminho** (olha para o diagrama!); (3) escreve a regra em cada firewall no formato: *FW-X, zona A → zona B: permitir TCP, src=rede/host, sport=..., dst=servidor, dport=...*; (4) lembra-te das ligações de **retorno** (implícitas se stateful); (5) termina com **deny all** implícito/explicito. Não esquecer fluxos «secundários»: o backup que recolhe da DMZ E do datacenter, e que depois envia para o exterior, gera regras em firewalls diferentes.

2.3 Casos especiais que caem sempre

- **OpenVPN na DMZ:** permitir exterior → servidor OpenVPN (UDP 1194 por omissão, ou TCP/UDP 443); depois, regras da rede virtual (192.168.10.0/24) → apenas os serviços autorizados (ex.: Datacenter B). O tráfego desencapsulado tem de voltar a passar pelas firewalls para chegar ao destino.
- **IPsec site-to-site:** permitir UDP 500 (IKE/ISAKMP), protocolo IP 50 (ESP) e/ou 51 (AH); com NAT-Traversal, UDP 4500. As regras aplicam-se entre as zonas dos gateways IPsec.
- **Half-open TCP / SYN flood:** firewalls stateful esgotam a tabela de estados; mitigação com SYN cookies, timeouts agressivos, limites por origem, ou stateless à frente.

■ **Onde estudar:** Flow_Control.pdf — slides 2 (micro-segmentação), 3–9 (firewalls, tipos, stateful/stateless, instâncias), 10–11 (colocação com redundância), 24–28 (regras: formato, multi-zona, exemplos e boas práticas), 31 (half-open TCP). Secure_Connections.pdf — slide 36 (portas de OpenVPN/IPsec para as regras).

3. Proteção contra DDoS e IP Spoofing ★★★★★■

3.1 Arquitetura multi-nível (a resposta-modelo)

- **1.ª linha stateless:** firewalls/filtros stateless junto aos routers de fronteira para descartar tráfego obviamente malicioso a alto débito sem esgotar estado.
- **2.ª linha stateful:** firewalls stateful (em cluster) para controlo fino por ligação.
- **Load balancers + clusters de firewalls/servidores:** distribuir carga (IP hash, round robin, least connections); ativo-ativo com sincronização de estado ou ativo-backup com VRRP/BFD para redundância de gateway.
- **Redundância de acesso:** dois ISPs/routers, caminhos alternativos, e capacidade excedentária.
- **Monitorização integrada para contenção:** deteção (NetFlow/probes/IDS) → identificação dos IPs atacantes → regras dinâmicas de bloqueio/rate-limiting na 1.ª linha (ou blackholing no ISP).

3.2 Anti-spoofing

- Nos routers/firewalls de fronteira: **negar tráfego externo com IP de origem das gamas internas** (e das gamas privadas/bogons); negar tráfego de saída cuja origem não pertença à rede interna (egress filtering / uRPF — só se aceita um pacote se a rota de retorno para a origem sair pela mesma interface).

■ **Onde estudar:** Flow_Control.pdf — slides 12 (VRRP/BFD), 13–15 (alta disponibilidade e clusters), 16–22 (load balancing, addressed vs. stealth), 23 (defesa multi-nível: stateless à frente, stateful atrás), 29–30 (IP spoofing e prevenção em L3), 31 (SYN flood). IDS_IPS.pdf — slides 7–9 (onde ligar sondas/IPS para detetar o ataque).

4. Ligações seguras: VPNs, IPsec e PKI ★★★★★■

4.1 Túneis e redes overlay (base conceptual)

- Túnel = encapsular o pacote original num protocolo de entrega; extremos definidos por VTIs ou loopbacks. Tipos: IPv4-in-IPv4, GRE (multi-protocolo), mGRE (multiponto).
- **Overlay**: rede virtual sobre a rede física; encaminhamento entre túneis por rotas estáticas, PBR ou routing dinâmico. **NHRP** mapeia endereços do overlay para endereços físicos (base do DMVPN).

4.2 IPsec (o mais importante)

- **Protocolos**: AH (autenticação/integridade, IP proto 51 — incompatível com NAT) e ESP (confidencialidade + integridade, IP proto 50). **Modos**: transporte (host-a-host) e túnel (gateway-a-gateway, o normal em site-to-site).
- **SAs (Security Associations)**: contrato unidirecional entre pares (algoritmos, chaves, SPI). Negociadas por **IKE/ISAKMP**: fase 1 (autenticação dos pares e canal seguro — main/aggressive mode; UDP 500) e fase 2 (SAs IPsec para o tráfego — quick mode). **NAT-T**: encapsula ESP em UDP 4500.
- **Seleção do tráfego a proteger**: por políticas/crypto ACLs (origem, destino, portas — ex.: só TCP 6002↔6002) ou por rotas para a VTI. É isto que respondes quando pedem «como definir o tráfego encaminhado/protegido».
- **Autenticação dos pares**: PSK (não escala) ou **certificados digitais** (a resposta esperada em 2025/2026).

4.3 Site-to-site com redes dinâmicas (pergunta recorrente 2023–2024)

- Lista de redes remotas **conhecida e estática** → túneis IPsec ponto-a-ponto com configuração estática (crypto maps).
- Redes remotas **dinâmicas** (VMs criadas/destruídas em clouds, várias localizações) → **DMVPN**: hub-and-spoke com mGRE + NHRP + IPsec; os spokes registam-se no hub e podem criar túneis spoke-to-spoke a pedido, sem reconfiguração. Alternativas modernas: WireGuard/Tailscale (mesh coordenada) ou SD-WAN/VPNaaS.

4.4 PKI: certificados e CA (em alta em 2025/2026)

- **X.509**: versão, n.º de série, emissor, validade, subject, chave pública, assinatura da CA. **CRL/OCSP** para revogação; validação = dentro da validade + CA confiável + não revogado + assinatura válida.
- **Enrollment com SCEP** (ou HTTP simples como no enunciado de 2026): o cliente gera par de chaves, envia CSR à CA, CA assina e devolve o certificado; obtém também o certificado da CA e a CRL.
- **CA interna sem acesso do exterior** (2025 Q3c / 2026 Q2-iii): os equipamentos internos fazem enrollment por HTTP/80 **dentro** da rede (regras de FW só entre as zonas internas e a zona da CA); os certificados/CRL necessários a pares externos são distribuídos fora de banda ou publicados num repositório na DMZ — a CA em si nunca é exposta.
- **Remote access**: OpenVPN (SSL/TLS; UDP/TCP 1194 ou 443; auth por certificado, PSK ou login), L2TP/IPsec, WireGuard (NoiseIK, forward secrecy). Integração na rede: servidor na DMZ e tráfego desencapsulado re-inspecionado pelas firewalls.

■ **Onde estudar**: Secure_Connections.pdf — slides 8–12 (PKI, X.509, SCEP, CRL, validação), 14–26 (túneis, VTI, GRE, overlay, NHRP, hub-spoke), 28–36 (remote access: OpenVPN, WireGuard, integração e portas), 38–48 (IPsec: AH/ESP, modos, SAs, IKE/ISAKMP fases), 55 (NAT-T), 56–57 (IPsec estático vs. DMVPN), 58–60 (OpenVPN site-to-site, SD-WAN).

5. Monitorização e SIEM ★★★★★

5.1 Fontes de dados e coleta (metade da resposta em qualquer alínea)

- **Logs** de servidores/serviços (web, DNS, auth) centralizados por **rsyslog**/agentes → LMS/SIEM.
- **SNMP**: estado e contadores de equipamentos (polling periódico + traps).
- **NetFlow/IPFIX**: registos de fluxos exportados por routers/switches — quem fala com quem, quanto, quando, que portas. Ideal para volumetria, exfiltração e varrimentos.
- **Sondas passivas / espelhamento**: network tap, mirror port ou ERSPAN (túnel GRE com tráfego espelhado) para análise detalhada (DPI/IDS). É assim que se «adquirem os dados» nas perguntas de DDoS.
- **EDR/NDR**: telemetria de endpoints e da rede para deteção comportamental.

5.2 SIEM, UEBA e SOAR

- SIEM = agregação + correlação de eventos multi-fonte + alertas + dashboards (vs. LMS que só armazena/pesquisa). Limitações: regras nativas stateless e thresholds fixos → complementar com **UEBA** (baselines de comportamento por utilizador/dispositivo, ML) e **SOAR** (orquestração e resposta automática). XDR integra tudo.

5.3 Receitas de regras de alerta (os cenários que caem sempre)

Estrutura da resposta: **fonte de dados** → **processo de coleta** → **2+ regras concretas com threshold/janela temporal**.

- **DDoS (clientes externos)**: NetFlow nos routers de fronteira + logs dos servidores. Regras: (1) n.º de novas ligações/pedidos por IP externo > X num intervalo T; (2) n.º total de IPs distintos a contactar o mesmo serviço > Y vs. baseline; (3) muitos SYN sem handshake completo por origem; (4) pedidos idênticos/erros repetidos por IP.
- **Exfiltração lenta via HTTPS/serviço autorizado**: NetFlow + logs de proxy. Regras: (1) volume acumulado de upload por terminal para o mesmo destino externo > X por dia (janela longa!); (2) rácio upload/download anómalo face à baseline do utilizador; (3) ligações persistentes/regulares (beaconing) fora do horário.
- **Exfiltração/C&C; via DNS**: logs do servidor DNS interno + NetFlow porta 53. Regras: (1) n.º de queries por terminal > X/min; (2) queries com nomes longos/alta entropia ou muitos subdomínios únicos do mesmo domínio; (3) tipos de registo invulgares (TXT/NULL) em volume; (4) queries diretas a DNS externos, contornando o interno.
- **Movimentação lateral / propagação de worms**: NetFlow interno (é preciso visibilidade leste-oeste — daí a segmentação!) + logs de autenticação. Regras: (1) um terminal contacta > N terminais internos distintos em T (scanning); (2) ligações a portas de serviços internos (445/SMB, RDP, SSH) entre terminais de utilizadores, que normalmente não comunicam entre si; (3) sequência de autenticações falhadas em múltiplas máquinas.
- **Testes de vulnerabilidade / brute force em servidores web**: logs do servidor HTTP + WAF/IDS. Regras: (1) taxa de erros 404/403/500 por IP > X em T (fuzzing de caminhos); (2) URLs com padrões de injeção (SQLi/XSS) ou user-agents de scanners; (3) logins falhados > X por IP/conta em T.
- **Botnet/C&C; via serviço legítimo (Twitter, Google Drive, OneDrive)**: NetFlow + proxy logs: comunicações periódicas de baixo volume (beaconing) para o serviço, a horas invulgares, de terminais sem uso habitual desse serviço; correlação de vários terminais com o mesmo padrão/destino.

■ **Onde estudar**: NetworkMonitoringSIEM.pdf — slides 3–7 (o que monitorizar), 8–17 (fontes: rsyslog, SNMP, NetFlow/IPFIX, sondas passivas), 19–21 (LMS vs. SIEM), 22 (exemplos de eventos SIEM — brute force, 404s), 23–26 (UEBA, limitações, SOAR, XDR), 28–29 (SOC, métricas). IDS_IPS.pdf — slides 7–8 (tap/mirror/ERSPAN para alimentar a análise).

6. Segmentação L2/L3: VLANs e arquitetura ★★★■ (Q1 de 2026 = 4 valores)

- **Porque é que uma só VLAN por edifício é má:** um único domínio de broadcast/L2 — qualquer terminal comprometido comunica diretamente (L2) com todos os outros sem passar por nenhum ponto de controlo; ARP spoofing, sniffing e worms propagam-se livremente; sem visibilidade nem filtragem do tráfego leste-oeste.
- **Resposta-modelo para «alterações L2/L3»:** criar múltiplas VLANs (por função/serviço/perfil de utilizador — micro-segmentação, até VLAN por dispositivo crítico); trunks 802.1Q só com as VLANs necessárias (prune!); inter-VLAN routing centralizado em switches L3/firewalls, forçando o tráfego entre VLANs a passar por pontos de controlo onde se aplicam ACLs/firewall e se recolhe NetFlow/espelhamento para monitorização.
- **Conceitos de apoio:** VLANs locais vs. end-to-end; isolamento de VLANs; STP para loops; redundância de gateway (VRRP); OSPF e rotas por omissão são o contexto dos anexos dos exames (custos =1, rotas por omissão anunciadas pelos routers de fronteira).

■ **Onde estudar:** Corporate_Network_Topics.pdf — slides 21–29 (VLANs, trunks 802.1Q, inter-VLAN routing, isolamento, micro-segmentação L2) — **esta é a parte examinável**; slides 2–19 (design hierárquico e redundância) e 33–43 (routing/OSPF básico) apenas para interpretar o anexo. O resto (EIGRP, IS-IS, redistribuição, detalhes de LSAs) podes saltar. Flow_Control.pdf — slide 2 (micro-segmentação/Zero Trust) liga este tema ao controlo de fluxos.

7. IDS / IPS / EDR / NDR ★★ ■■■ (matéria de suporte)

- **IDS** deteta e alerta (fora de linha); **IPS** está inline e bloqueia. Detecção por **assinaturas** (padrões conhecidos, poucos falsos positivos, não deteta novidades) vs. **anomalias** (baseline estatística/ML, deteta zero-days, mais falsos positivos).
- **Host-based (EDR)** nos endpoints/servidores vs. **network-based (NDR)** na rede.
- **Pontos de captura para IDS:** network tap, mirror/SPAN port, ou ERSPAN (espelhamento remoto por túnel GRE). **IPS:** inline, integrado ou embebido na firewall. Usa isto quando o exame pede «sistema integrado de aquisição e processamento de dados» (2026 Q3b): sondas/taps nos pontos de agregação + NetFlow + logs → SIEM → regras.

■ **Onde estudar:** IDS_IPS.pdf — slides 2–3 (IDS, assinatura vs. anomalia), 4–6 (EDR/NDR), 7–9 (deployment: tap, mirror, ERSPAN, inline).

8. Tópicos de baixa prioridade (ler na diagonal)

- **Fases de um ataque** (aquisição de conhecimento/reconhecimento → infiltração → expansão/movimentação lateral → exfiltração) e o fator humano (phishing, engenharia social, OSINT): caiu em 4 exames de 2023–2024 mas não em 2025 nem 2026. Sabe descrever cada fase em 2–3 frases por precaução, e liga as mitigações à segmentação + monitorização + filtragem (as respostas de rede que já estudaste cobrem isto).
- **Access Control (802.1X, EAP, RADIUS/TACACS+, WiFi/WPA):** nunca foi perguntado diretamente em nenhum dos 7 exames. Fica com as ideias: 802.1X = controlo de acesso à porta (supplicant/authenticator/authentication server), RADIUS = AAA centralizado. Útil no máximo como medida complementar numa resposta de arquitetura.

■ **Onde estudar:** Access_Control.pdf — slides 2–4 (802.1X e AAA) e 9 (RADIUS) chegam. O detalhe WiFi (slides 16–30) é dispensável para o exame.

9. Checklist final antes do exame

- Sei desenhar zonas sobre o diagrama do anexo e justificar cada uma.

- Sei escrever regras de firewall completas (FW + zonas + sentido + IP/porta + ação) para: serviço público na DMZ, intranet restrita a VLANs, servidor de backup multi-origem com envio ao exterior, OpenVPN, IPsec (500/4500/ESP).
- Sei a arquitetura anti-DDoS de cor: stateless à frente → load balancers → stateful em cluster → detecção (NetFlow/sondas) → contenção dinâmica; + anti-spoofing (ingress/egress filtering, uRPF).
- Sei escolher entre IPsec estático (redes conhecidas) e DMVPN (redes dinâmicas na cloud) e justificar.
- Sei explicar o enrollment de certificados com uma CA interna protegida e as regras de FW associadas.
- Para cada cenário SIEM, digo sempre: fonte de dados + como é coletada + ≥ 2 regras com métricas, thresholds e janelas temporais concretas.
- Sei explicar porque VLANs únicas facilitam propagação e propor micro-segmentação L2/L3.